SIMATS ENGINEERING

CSA6303- Threat Intelligence and Network Security

A1-Threat Intelligence Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	10 (all compulsory)	**Marks per Question**	5
Reg.No	192425089	**Name**	G. Aswartha Manidheep
Faculty	Dr.V.Parthipan	**Slot**	A

Instructions: Answer all questions. Each question carries 5 marks. Support answers with examples and diagrams where appropriate.

Code of Conduct:

I G. Aswartha Manidheep (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of Student

Questions

Q1. Malware [5 Marks]

Define malware and explain any four types of malware (virus, worm, trojan, ransomware, spyware). For each type, state how it spreads and one impact on the victim.

Q2. Phishing [5 Marks]

Describe how a phishing attack is carried out. Differentiate between spear phishing, whaling and vishing, and list three measures an organisation can adopt to reduce phishing risk.

Q3. DoS and DDoS [5 Marks]

Distinguish between a Denial of Service (DoS) attack and a Distributed Denial of Service (DDoS) attack. Explain the working of a SYN flood and outline two mitigation techniques.

Q4. Man-in-the-Middle Attacks [5 Marks]

What is a Man-in-the-Middle (MITM) attack? Explain two techniques used to carry it out (for example ARP poisoning, rogue Wi-Fi access point, SSL stripping) and state how encryption helps defend against it.

Q5. Spoofing and Sniffing [5 Marks]

Compare spoofing and sniffing. Explain IP spoofing and ARP spoofing with an example each, and describe how packet sniffers such as Wireshark can be used both maliciously and legitimately.

Q6. Vulnerability Assessment [5 Marks]

Explain the vulnerability assessment process. Describe its main phases, and differentiate between vulnerability assessment and penetration testing. Name two commonly used scanning tools.

Q7. Vulnerability Scoring [5 Marks]

What are CVE and CVSS? Explain how CVSS scores help in prioritising vulnerabilities and why a high CVSS score alone may not decide the order of patching.

Q8. Threat Data Sources and OSINT [5 Marks]

Discuss the main sources of threat data (internal, external, open-source and commercial). Define Open-Source Intelligence (OSINT) and describe three OSINT sources or tools used in threat intelligence gathering.

Q9. Indicators of Compromise (IoCs) [5 Marks]

What are Indicators of Compromise (IoCs)? Classify them into network-based, host-based and file-based indicators with two examples of each, and explain how a security team uses IoCs during incident response.

Q10. Threat Feeds [5 Marks]

Explain what a threat intelligence feed is. Describe the common feed formats and sharing standards (STIX/TAXII), list two advantages and two limitations of using threat feeds, and name two example feeds.

Marking Scheme (for evaluator)

Q.No	Expected points and mark distribution (total 5)
1	Definition (1); four types with spread method and impact (4 x 1 = 4).
2	Attack flow (1.5); three variants differentiated (1.5); three countermeasures (2).
3	DoS vs DDoS (1.5); SYN flood working (1.5); two mitigations such as rate limiting, SYN cookies, CDN/scrubbing, blackhole routing (2).
4	Definition and interception concept (1); two techniques (2); defences such as TLS, HSTS, certificate validation, VPN (2).
5	Comparison (1); IP and ARP spoofing with examples (2); sniffer dual use (1.5); one countermeasure (0.5).
6	Phases: asset discovery, scanning, analysis and prioritisation, reporting, remediation (2); VA vs pen test (2); two tools such as Nessus, OpenVAS, Qualys (1).
7	CVE meaning (1); CVSS meaning and severity ratings (1.5); role in prioritisation (1.5); context factors such as exploitability and asset criticality (1).
8	Threat data source categories (2); OSINT definition (1); three OSINT sources or tools such as Shodan, VirusTotal, WHOIS, social media, dark web monitoring (2).
9	Definition (1); classification with examples (3); use in detection and response (1).

Q.No	Expected points and mark distribution (total 5)
10	Definition (1); STIX/TAXII or similar formats (1.5); two advantages and two limitations (2); two example feeds such as AlienVault OTX, MISP, abuse.ch (0.5).

ANSWERS

CSA6303 – Threat Intelligence and Network Security | A1 – Threat Intelligence Report

Q1. Malware [5 Marks]

Definition: Malware (malicious software) is any program or code deliberately designed to infiltrate, damage, disrupt, or gain unauthorised access to a computer system, network or data without the owner's consent.

Type	How it spreads	Impact on victim
Virus	Attaches itself to a legitimate file/program; spreads when the infected file is executed or shared (USB, email attachments, downloads).	Corrupts or deletes files and slows or crashes the system.
Worm	Self-replicates and spreads on its own across networks by exploiting vulnerabilities (e.g., WannaCry via SMB) – no user action or host file needed.	Consumes bandwidth and resources, causing network-wide outages and enabling further payloads.
Trojan	Disguised as useful or legitimate software (cracked apps, fake installers, email attachments); user installs it willingly. Does not self-replicate.	Opens a backdoor for remote control, data theft or installation of other malware.
Ransomware	Delivered via phishing emails, malicious downloads or exploited RDP/vulnerabilities; encrypts files after execution.	Files become inaccessible until a ransom is paid; causes data loss and business downtime.
Spyware	Bundled with free software, drive-by downloads or malicious links; runs silently in the background.	Steals passwords, banking details and browsing activity (keylogging), leading to identity theft.

Note: The question asks for any four types; five are given above for completeness.

Q2. Phishing [5 Marks]

How a phishing attack is carried out

- **Reconnaissance/planning:** attacker picks a target and a trusted brand (bank, courier, IT department).
- **Lure creation:** a fake email, SMS or website that imitates the trusted entity is crafted, with urgency ("account will be blocked").
- **Delivery:** the message is sent with a malicious link or attachment.
- **Victim interaction:** the victim clicks, lands on a cloned login page and enters credentials or opens the attachment.
- **Exploitation:** credentials are harvested or malware is installed; the attacker then misuses accounts, steals money or moves deeper into the network.

Differences between variants

Attack	Target	Method
Spear phishing	A specific individual or small group	Highly personalised email using information gathered about the victim (name, role, colleagues).
Whaling	Senior executives (CEO, CFO, directors)	Spear phishing aimed at "big fish", e.g., fake legal notice or urgent wire-transfer request, to cause large financial or data loss.
Vishing	Anyone, via telephone	Voice phishing – the caller impersonates a bank or support agent and tricks the victim into revealing OTPs, PINs or card details.

Three organisational measures

- **Security awareness training** and regular simulated phishing exercises for all staff.
- **Email security controls:** spam/phishing filters, SPF, DKIM and DMARC, link and attachment sandboxing.
- **Multi-factor authentication (MFA)** and a clear procedure to report suspicious emails, so stolen passwords alone are not enough.

Q3. DoS and DDoS [5 Marks]

Basis	DoS	DDoS
Source of attack	Single machine/connection	Many compromised machines (botnet) across the world
Scale/volume	Limited by one attacker's bandwidth	Very large (Gbps–Tbps)
Detection/blocking	Easy – block the single source IP	Hard – traffic comes from thousands of legitimate-looking IPs
Example	Ping flood from one PC	Mirai botnet attack

SYN flood – working

A SYN flood exploits the TCP three-way handshake (SYN → SYN-ACK → ACK).

- The attacker sends a large number of SYN packets, usually with spoofed source IP addresses.
- The server replies with SYN-ACK and keeps a half-open connection in its backlog queue, waiting for the final ACK.
- The ACK never arrives (spoofed addresses do not respond), so the backlog queue fills up.
- Legitimate users' connection requests are dropped and the service becomes unavailable.

Two mitigation techniques

- **SYN cookies:** the server does not store state for half-open connections; it encodes connection details in the sequence number and allocates resources only when a valid ACK returns.
- **Rate limiting / firewall filtering:** limit SYN packets per source and drop spoofed traffic; additionally use CDN/scrubbing services or blackhole routing for large DDoS floods.

Q4. Man-in-the-Middle Attacks [5 Marks]

Definition: In a Man-in-the-Middle (MITM) attack, an attacker secretly positions himself between two communicating parties (e.g., user and website), intercepting, reading and possibly altering the data while both sides believe they are talking directly to each other.

```
Victim  <-------->  ATTACKER  <-------->  Server/Website
          (reads / modifies traffic)
```

Techniques

- **ARP poisoning:** the attacker sends forged ARP replies on a LAN linking his MAC address to the gateway's IP. Victims' traffic is sent to the attacker, who forwards it onward after capturing it.
- **Rogue Wi-Fi access point (evil twin):** the attacker sets up a fake hotspot with a familiar name (e.g., "Free_Airport_WiFi"). Users connect and all their traffic passes through the attacker's device.
- **SSL stripping:** the attacker downgrades an HTTPS connection to HTTP so data is sent in plaintext.

How encryption helps

- **TLS/HTTPS** encrypts data in transit, so intercepted traffic is unreadable and tampering is detected.
- **Certificate validation** ensures the server's identity; a forged certificate triggers browser warnings.
- **HSTS** forces browsers to use HTTPS and defeats SSL stripping; a **VPN** encrypts all traffic on untrusted networks such as public Wi-Fi.

Q5. Spoofing and Sniffing [5 Marks]

Basis	Spoofing	Sniffing
Nature	Active – forges identity (IP, MAC, email) to impersonate a trusted entity	Passive – captures and monitors network traffic
Goal	Deceive systems/users, bypass access control, hide origin	Gather information (passwords, data) or analyse traffic
Detectability	Can be detected through anomalies	Hard to detect as it does not alter traffic

IP spoofing

The attacker forges the source IP address in packet headers to hide identity or impersonate another host. **Example:** in a SYN flood or a DDoS reflection attack, packets carry the victim's IP as source, so replies flood the victim.

ARP spoofing

The attacker sends false ARP messages to map his MAC address to a legitimate IP (e.g., the default gateway). **Example:** on an office LAN the attacker poisons the ARP cache of a user so that all outgoing traffic goes through him, enabling a MITM attack.

Packet sniffers (e.g., Wireshark)

Malicious use	Legitimate use
Capturing unencrypted credentials, session cookies and emails on open/shared networks; reconnaissance before an attack.	Network troubleshooting, performance analysis, protocol debugging, detecting malware communication and forensic investigation by administrators.

Countermeasure: use encryption (HTTPS/SSH/VPN), Dynamic ARP Inspection, static ARP entries and ingress/egress filtering to reduce both attacks.

Q6. Vulnerability Assessment [5 Marks]

Vulnerability assessment (VA) is the systematic process of identifying, classifying and prioritising security weaknesses in systems, networks and applications.

Main phases

- **Asset discovery:** identify all hosts, devices, applications and services in scope.
- **Vulnerability scanning:** use automated tools to detect missing patches, misconfigurations and weak settings.
- **Analysis and prioritisation:** remove false positives and rank findings by severity and business impact.
- **Reporting:** document vulnerabilities, risk ratings and recommendations.
- **Remediation and re-scan:** patch or mitigate the issues and verify the fixes.

Vulnerability assessment vs penetration testing

Basis	Vulnerability Assessment	Penetration Testing
Objective	Find and list as many weaknesses as possible	Exploit weaknesses to show real-world impact
Approach	Mostly automated, broad	Manual and automated, deep and targeted
Exploitation	Does not exploit	Actively exploits vulnerabilities
Output	List of vulnerabilities with severity	Proof of compromise with attack paths
Frequency	Regular (monthly/quarterly)	Periodic (annual/after major change)

Common scanning tools: Nessus and OpenVAS (also Qualys).

Q7. Vulnerability Scoring [5 Marks]

CVE (Common Vulnerabilities and Exposures): a standard dictionary that assigns a unique identifier to every publicly known vulnerability (format CVE-YYYY-NNNN, e.g., CVE-2021-44228 for Log4Shell), so everyone refers to the same flaw.

CVSS (Common Vulnerability Scoring System): an open framework that rates the severity of a vulnerability on a 0–10 scale using base metrics (attack vector, complexity, privileges required, user interaction, impact on confidentiality/integrity/availability), plus temporal and environmental metrics.

Score	Severity
0.0	None
0.1 – 3.9	Low
4.0 – 6.9	Medium
7.0 – 8.9	High
9.0 – 10.0	Critical

Role in prioritisation

CVSS gives a common, objective numeric rating, letting teams sort thousands of findings and fix Critical/High ones first, set SLAs for patching and report risk consistently.

Why a high CVSS score alone is not enough

- **Exploitability in the wild:** a medium-score flaw with a public exploit may be more urgent than a high-score flaw with none.
- **Asset criticality:** a flaw on an internet-facing payment server matters more than the same flaw on an isolated test machine.
- **Other context:** existing compensating controls, network exposure, data sensitivity and availability of patches.

Q8. Threat Data Sources and OSINT [5 Marks]

Source type	Description	Examples
Internal	Data generated within the organisation	Firewall/IDS/IPS logs, SIEM events, endpoint (EDR) telemetry, DNS and email logs, past incident reports
External	Data obtained from outside organisations/communities	Government CERTs (CERT-In, US-CERT), ISACs, vendor advisories, industry sharing groups
Open-source	Freely available public information	Blogs, security forums, vulnerability databases (NVD), public threat feeds, social media
Commercial	Paid, curated intelligence with analysis and support	CrowdStrike, Recorded Future, Mandiant, Palo Alto Unit 42 subscriptions

OSINT (Open-Source Intelligence): intelligence produced by collecting and analysing information from publicly available sources to support security decisions, such as identifying attacker infrastructure, leaked credentials or exposed assets.

Three OSINT sources/tools

- **Shodan:** search engine for internet-connected devices; reveals exposed servers, open ports and vulnerable services.
- **VirusTotal:** analyses files, URLs, domains and IPs with many antivirus engines and shows reputation and relationships of indicators.
- **WHOIS (and similar tools like social media / dark-web monitoring):** domain registration details used to trace attacker infrastructure and identify newly registered malicious domains.

Q9. Indicators of Compromise (IoCs) [5 Marks]

Definition: Indicators of Compromise are pieces of forensic evidence or artefacts that show a system or network has been breached or is under attack, e.g., malicious IPs, file hashes or unusual registry changes. They help detect known threats.

Category	Meaning	Two examples
Network-based	Observed in network traffic	1. Communication with a known malicious IP/domain (C2 server) 2. Unusual outbound traffic volume or beaconing on odd ports
Host-based	Seen on an endpoint/server	1. New unknown user accounts or unexpected registry/startup changes 2. Suspicious processes or unusual login times
File-based	Properties of malicious files	1. File hash (MD5/SHA-256) matching known malware 2. Suspicious file names/paths or unexpected modified system files

Use during incident response

- **Detection:** IoCs are loaded into SIEM, IDS and EDR tools to alert on matches.
- **Scoping and containment:** search logs and endpoints for the same IoCs to find all affected systems, then isolate them and block the malicious IPs/domains/hashes.
- **Eradication and sharing:** guide cleanup and share IoCs with partners to prevent further attacks.

Q10. Threat Feeds [5 Marks]

Definition: A threat intelligence feed is a continuously updated stream of data about threats – such as malicious IPs, domains, URLs, file hashes and attacker tactics – delivered in machine-readable form so security tools can automatically use it.

Formats and sharing standards

- **STIX (Structured Threat Information eXpression):** a standardised language/JSON format to describe threat information (indicators, malware, threat actors, campaigns).
- **TAXII (Trusted Automated eXchange of Intelligence Information):** the transport protocol used to exchange STIX data between organisations over HTTPS.
- **Other common formats:** CSV, JSON, XML and OpenIOC.

Advantages	Limitations
1. Real-time, automated detection and blocking of known threats	1. Can produce false positives and stale/outdated indicators
2. Broader visibility beyond the organisation's own data; saves analysis effort	2. Lacks context, and huge volume can overwhelm analysts; quality varies between sources

Example feeds: AlienVault OTX and abuse.ch (also MISP).